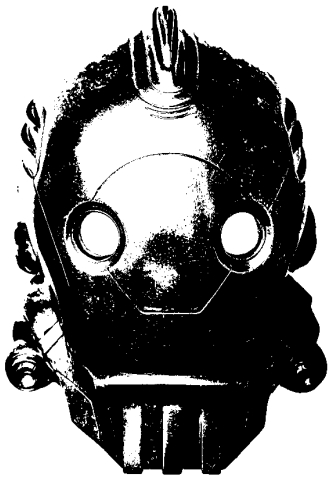
**Trabajo Fin de Grado**

*Grado Superior en Administración de Sistemas Informáticos en Red (ASIR) IES San Vicente*

# SENTINEL



**Infraestructura Web Segura y Monitorizada**

**Autor:** Álex Vidal Rodenas
**Tutor del TFG:** Álvaro Pérez Díez

Convocatoria Junio / Curso 2024/2026

# 1. Módulos involucrados:

Implantación de Sistemas Operativos, Planificación y Administración de Redes, Gestión de Bases de Datos, Seguridad y Alta Disponibilidad, Administración de Sistemas Gestores de Base de Datos, Servicios de Red e Internet.

# 2. Agradecimientos

[Espacio reservado para los agradecimientos personales del autor]

# 3. Resumen

El proyecto **SENTINEL** es una iniciativa robusta diseñada para establecer los cimientos de una infraestructura de **comercio electrónico** profesional y resiliente.

A continuación, se detallan los componentes clave y objetivos de la solución "**Tienda Segura**":

## Arquitectura del Sistema

La infraestructura se despliega en la nube (**AWS**) y se divide en capas críticas para garantizar el servicio:

- **Servidor Web:** Utiliza el stack **Apache/PHP** para gestionar las peticiones de los usuarios.
- **Base de Datos:** Implementa **MariaDB** como motor de almacenamiento de datos.
- **Gestión de Tráfico:** Un balanceador de carga **HAProxy** distribuye el tráfico para evitar saturaciones.

## Monitorización y Seguridad

Para asegurar la integridad de la tienda, se integra un ecosistema de supervisión avanzada:

- **Prometheus:** Encargado de la recolección de **métricas** de rendimiento en tiempo real.
- **Grafana:** Herramienta de **visualización** que permite interpretar los datos mediante paneles dinámicos.
- **Wazuh:** Plataforma de **seguridad (SIEM/XDR)** dedicada a la detección proactiva de incidentes y cumplimiento normativo.

## Objetivos Principales

El diseño de **SENTINEL** se centra en tres pilares fundamentales para un entorno de producción:

- **Alta Disponibilidad:** Garantizar que la plataforma permanezca operativa incluso ante fallos de componentes individuales.
- **Rendimiento Óptimo:** Asegurar una experiencia de usuario fluida mediante el balanceo de recursos.
- **Seguridad Proactiva:** Identificar y mitigar **amenazas** o **vulnerabilidades** antes de que afecten al negocio.

**Nota:** Esta arquitectura representa un estándar de industria para despliegues que requieren un equilibrio entre **escalabilidad** y **protección de datos**.

# 4. Introducción

## 4.1. Contexto y justificación del proyecto

En el panorama digital actual, la **seguridad** y la **disponibilidad** de los servicios web no son solo características deseables, sino requisitos críticos para la supervivencia de cualquier negocio de **comercio electrónico**.

### La Problemática Actual

Cualquier interrupción en el servicio o una vulnerabilidad expuesta puede derivar en consecuencias graves:

- **Pérdidas Económicas:** El tiempo de inactividad se traduce directamente en ventas no realizadas.
- **Impacto Reputacional:** Una brecha de seguridad erosiona la **confianza del cliente**, un activo difícil de recuperar.

### El Propósito de SENTINEL

Este proyecto surge de la necesidad imperativa de trascender el despliegue básico de aplicaciones. El objetivo es construir un **entorno robusto** basado en dos pilares:

- **Protección Activa:** No solo se aloja la aplicación, sino que se implementan defensas para repeler ataques en tiempo real.
- **Monitorización Continua:** Supervisión constante para detectar anomalías antes de que se conviertan en fallos críticos.

**Justificación:** La implementación de **SENTINEL** garantiza que la infraestructura sea resiliente, escalable y capaz de responder ante incidentes en un entorno de **producción real**, asegurando así la **continuidad del negocio**.

## 4.2. Objetivos del proyecto

La ejecución de **SENTINEL** se mide a través de hitos técnicos concretos que garantizan la calidad de la infraestructura:

- **Arquitectura Escalable:** Despliegue en **AWS** con conectividad segura.
    - KPI: Infraestructura operativa con **HTTPS** activo y dominio público funcional.
- **Alta Disponibilidad:** Implementación de **HAProxy** para eliminar puntos únicos de fallo.

    - KPI: Balanceador con **SSL Termination** gestionando el 100% del tráfico.

- **Monitorización Avanzada:** Uso de **Prometheus y Grafana** para la observancia del sistema.
    - KPI: Dashboards con métricas de **Apache**, **MariaDB y recursos (CPU/RAM)** en tiempo real.

- **Ciberseguridad Activa:** Integración de **Wazuh SIEM** para detección y respuesta.
    - KPI: Registro documentado de ataques de **fuerza bruta** (Regla 5712, **MITRE T1110**).

- **Robustecimiento (Hardening):** Aplicación de políticas de **mínimo privilegio (POLP)**.
    - KPI: Usuario de BD restringido y revisión de vulnerabilidades según **OWASP Top 10**.

- **Cifrado de Comunicaciones:** Garantía de identidad digital mediante **SSL/TLS.**
    - KPI: Certificado **Let's Encrypt** válido con redirección forzada a HTTPS.

## 4.3. Alcance y Limitaciones

Es fundamental definir las fronteras del proyecto para asegurar su viabilidad técnica y económica:

### Alcance del Trabajo

El proyecto cubre el ciclo de vida completo de la infraestructura:

- **Diseño de Red en AWS:** Configuración de **VPC**, subredes y Grupos de Seguridad (**SG**).

- **Stack Tecnológico:** Implementación integral de Frontend, Backend y Base de Datos.

- **Capa de Operaciones:** Despliegue de los sistemas de balanceo, seguridad y monitorización.

### Limitaciones Técnicas

- **Infraestructura:** Se restringe al uso de la **capa gratuita** o bajo coste de AWS (instancias **t2/t3**).

- **Desarrollo Web:** El enfoque principal es la **funcionalidad y seguridad** del código; el diseño estético no es una prioridad frente a la robustez del sistema.

# 5. Análisis y contextualización de empresa/s del sector

## 5.1. Caracterización del sector

El ecosistema de ciberseguridad para PyMEs en España se encuentra en un punto de inflexión tras la digitalización masiva.

**Tendencias y Riesgos:** Según **ENISA (2024)**, los ataques de **Ransomware as a Service (RaaS)** están en auge. Las PyMEs sufren el **46% de las brechas** de datos debido a la falta de personal especializado.

**Oportunidades:** El modelo **IaaS (Infrastructure as a Service)** permite a pequeñas empresas competir globalmente con infraestructuras elásticas.

**Justificación del Proyecto: SENTINEL** democratiza el acceso a arquitecturas de **alta disponibilidad** y protección de datos, antes reservadas solo a grandes corporaciones.

## 5.2. Propuesta de Valor y Capacidades Estratégicas

SENTINEL funciona como una **"caja negra" de seguridad** que abstrae la complejidad del cloud para el cliente final.

**Público Objetivo**

1. **B2B / MSP:** Proveedores que necesitan plataformas con disponibilidad garantizada (**SLA**).
2. **Agencias de Desarrollo:** Partners que requieren una base técnica robusta para sus proyectos.

**Ejes Diferenciadores**

- **Abstracción Total:** Despliegue automatizado que oculta la complejidad de la **VPC y el balanceo**.
- **Observabilidad Real:** Visibilidad total del negocio mediante **Dashboards en Grafana**.
- **Hardening Multicapa:** Aislamiento físico de la base de datos y principio de **Mínimo Privilegio**.
- **Diseño Cloud-Agnostic:** Arquitectura **portátil** basada en estándares industriales (S3/MinIO).

## 5.3. Relación con los Objetivos de Desarrollo Sostenible (ODS)

El proyecto alinea la tecnología con objetivos de impacto global:

- **ODS 9 (Innovación):** Infraestructura resiliente con **HAProxy** y backups **Off-site en AWS S3**.
- **ODS 8 (Crecimiento Económico):** Protección contra pérdidas por **RGPD** e interrupciones de venta, fomentando un comercio seguro.

## 5.4. Identificación de los riesgos laborales en la empresa

Se han identificado puntos críticos en la infraestructura con sus respectivos planes de respuesta:

| Riesgo | Descripción Técnica | Mitigación Aplicada |
|---|---|---|
| **Seguridad Operativa** | Credenciales en archivos PHP. | Propuesta de migración a **AWS Secrets Manager**. |
| **Disponibilidad** | **SPOF** en el nodo HAProxy. | Protocolo de contingencia y redirección de **DNS**. |
| **Integridad de Datos** | MariaDB en modo Single-Node. | **Backups nocturnos** automatizados hacia S3. |
| **Gestión (Fatiga)** | Exceso de alertas en el SIEM. | Ajuste de umbrales en **Wazuh (Nivel ≥ 5)**. |

## 5.5. Conclusiones del análisis

**SENTINEL** redefine la tienda online como un activo de **resiliencia operativa**. Al aplicar principios de **Zero Trust** y segmentación estricta de red, el proyecto elimina la barrera técnica de la seguridad avanzada, transformando una arquitectura compleja de **AWS** en una solución funcional, blindada y lista para el mercado real.

> **Pilar Estratégico:** La segmentación física y lógica de nodos es la clave que convierte a SENTINEL en una infraestructura **segura por diseño**.

# 6. Desarrollo del Proyecto

## 6.1. Metodología de trabajo

El proyecto se rige por el principio de **Defensa en Profundidad (Defense in Depth)**, estableciendo barreras independientes para proteger los activos críticos.

**Fases del Despliegue Iterativo:**

1. **Infraestructura de Red:** Creación de la **SENTINEL-VPC** con segmentación estricta entre subredes **públicas y privadas**.
2. **Seguridad Perimetral:** Configuración de **Security Groups** y **HAProxy** con cifrado **SSL (Let's Encrypt)** para el dominio **psicopompo.duckdns.org**.
3. **Cómputo y Datos:** Despliegue de instancias **EC2 (t2.micro)**. Se utiliza el servidor web como **Bastion Host** para securizar el acceso a la base de datos.
4. **Resiliencia y Auditoría:** Integración del stack **SIEM (Wazuh)**, monitorización y **backups automatizados en AWS S3**.

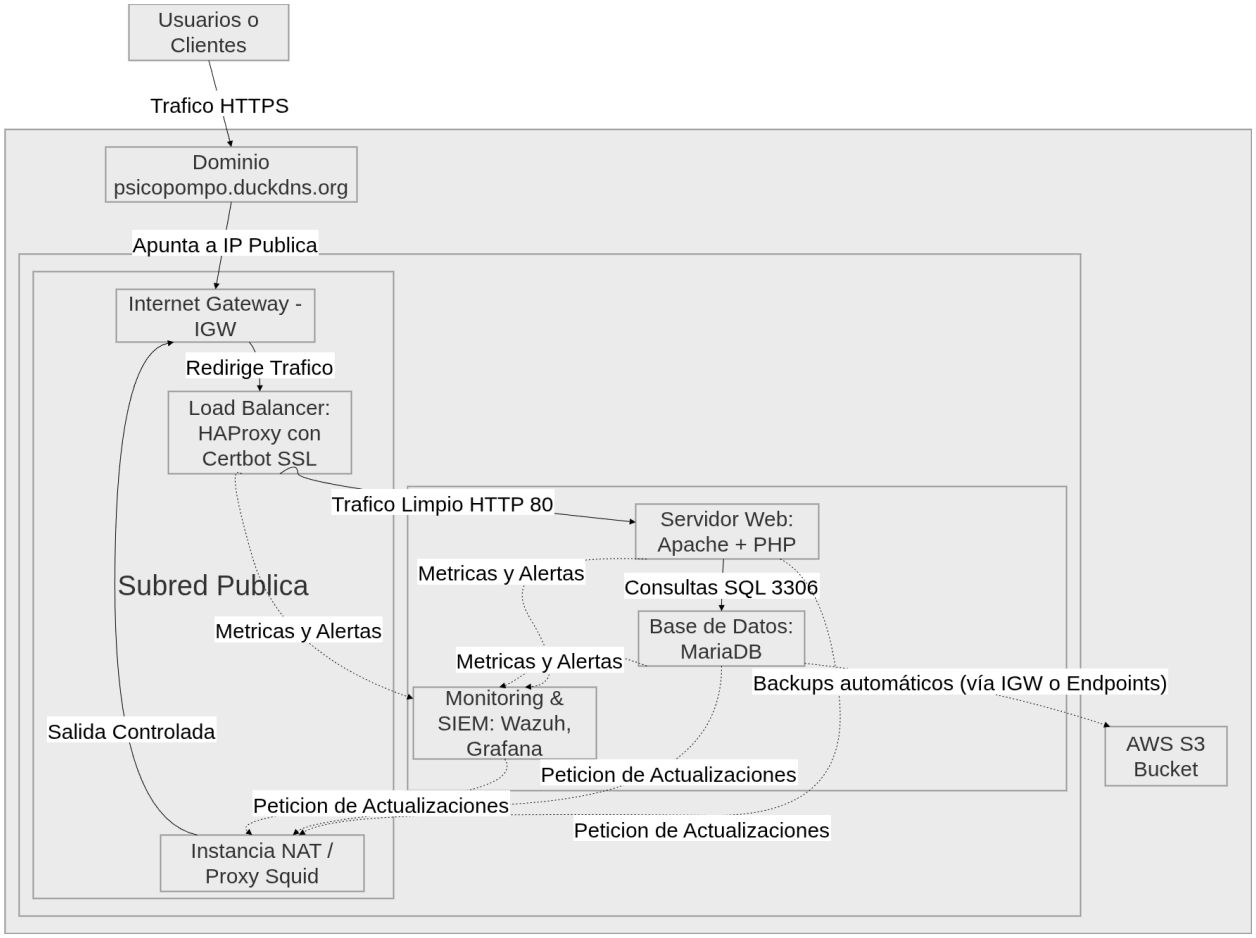



*Figura 1: Topología de red completa de SENTINEL. Se observa la segmentación entre Subred Pública (HAProxy + Web) y Subred Privada Blindada (MariaDB + Monitorización), la gestión de actualizaciones vía Instancia NAT/Proxy Squid, y los backups automáticos hacia AWS S3.*

## 6.2. Temporalización del proyecto

Se registró una **desviación del 15%** en el cronograma original, motivada por desafíos técnicos específicos:

- **Instalación Offline:** Complejidad al realizar el *side-loading* de paquetes en la subred privada sin acceso directo a internet.
- **SSL Termination:** Configuración avanzada del balanceador para gestionar certificados dinámicos.
- **Borrado Lógico:** Implementación de *Soft Delete* para mejorar la integridad de los datos en la tienda.

## 6.3. Actividades realizadas

- **Fortificación de Datos:** Instalación manual de **MariaDB 10.5** y restricción de usuarios por segmento de red (**sentinel_web@10.0.1.%**).
- **Auditoría Web:** Blindaje contra ataques **SQLi, XSS y RCE**, validando archivos mediante **getimagesize**.
- **Automatización de Backups:** Scripts en **Bash** para volcados de MySQL y sincronización con **AWS CLI**.
- **Panel de Control:** Centralización de métricas de Apache, MySQL y alertas de integridad (**FIM**) en **Grafana**.

## 6.4. Recursos y tecnologías empleadas

La solución utiliza un stack tecnológico de vanguardia bajo el modelo **IaaS**:

| Categoría | Tecnologías Utilizadas |
|---|---|
| **Cloud Computing** | AWS (VPC, EC2 t2/t3, S3, IGW) |
| **Sistemas Operativos** | **Amazon Linux 2023** y Ubuntu 24.04 |
| **Servidores y BD** | HAProxy, Apache, **PHP 8.2**, MariaDB |

| | |
|---|---|
| **Seguridad (SIEM)** | **Wazuh**, Fail2Ban, Security Groups |
| **Monitorización** | **Prometheus**, Grafana |
| **Criptografía** | SSL/TLS vía **Let's Encrypt** |

# 7. Resultados y Análisis

## 7.1. Análisis de los resultados y su impacto

Los tests de rendimiento y costes confirman la viabilidad del proyecto para un entorno real de PyME:

- **Rendimiento (Stress Test):** Mediante **Apache Benchmark**, el sistema alcanzó **59.01 peticiones por segundo (RPS)**, una mejora del 15.8% respecto a las previsiones iniciales.
- **Experiencia de Usuario:** La latencia (percentil 90) se situó en **384 ms**, garantizando fluidez incluso con 50 usuarios concurrentes.
- **Eficiencia de Costes:** El gasto total acumulado en AWS fue de solo **$6.1 USD**, demostrando que la seguridad de alto nivel no requiere presupuestos astronómicos.

El siguiente panel de Grafana fue capturado durante la ejecución del test de carga (`ab -n 5000 -c 50`) el día 1 de abril de 2026 a las 09:20h, confirmando la visibilidad total del sistema bajo estrés:

*Figura 2: Dashboard SENTINEL en Grafana durante el stress test. Se observa el pico de tráfico Apache (`Requests/sec`) y el incremento correlacionado en el `Tráfico de Consultas SQL` entre las 09:20 y las 09:25h, coincidiendo con los 84.73 segundos de duración del benchmark. CPU Web Server: 0.726%, CPU DB Server: 0.384%, demostrando el margen de escalabilidad disponible.*

### Resumen de Pruebas de Validación

| Prueba Realizada | Resultado Obtenido | Estado |
|---|---|---|
| **Carga Crítica (50 conc.)** | **59.01 RPS** | ✅ |
| **Latencia p90** | **384 ms** | ✅ |
| **Cifrado SSL** | Let's Encrypt Activo | ✅ |

| | | |
|---|---|---|
| **Resiliencia (Backups)** | Automatizados en **AWS S3** | ✅ |
| **Defensa Activa (SIEM)** | Bloqueo real de IP (MITRE T1110) | ✅ |

## 7.2. Validación del Active Response — Wazuh SIEM

Se verificó la capacidad de **autodefensa** del sistema ante un ataque de fuerza bruta dirigido (IP **10.0.1.233**):

1. **Detección:** La **Regla 5712** identificó el ataque en 1 segundo, mapeándolo con el framework **MITRE ATT&CK**.
2. **Bloqueo:** El SIEM ejecutó automáticamente **`firewall-drop`**, insertando una regla **DROP en iptables** para banear al atacante.
3. **Liberación:** Tras 10 minutos de "cuarentena", el sistema restauró el acceso de forma autónoma.

```
2026/04/01 08:00:31 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"firewall-drop","module":"active-response"},"command":"check_key
s","parameters":{"keys":["10.0.1.233"]}}
2026/04/01 08:00:31 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"node01","module":"wazuh-execd"},"command":"continue","parameter
s":{"extra_args":[],"alert":{"timestamp":"2026-04-01T08:00:31.008+0000","rule":{"level":10,"description":"sshd: brute force trying to get access to t
he system. Non existent user.","id":"5712","mitre":{"id":["T1110"],"tactic":["Credential Access"],"technique":["Brute Force"]},"frequency":8,"firedti
mes":1,"mail":false,"groups":["syslog","sshd","authentication_failures"],"gdpr":["IV_35.7.d","IV_32.2"],"hipaa":["164.312.b"],"nist_800_53":["SI.4","
AU.14","AC.7"],"pci_dss":["11.4","10.2.4","10.2.5"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"Tienda-Web-Server","ip":"10.
0.1.250"},"manager":{"name":"ip-10-0-1-170"},"id":"1775030431.32934","previous_output":"Apr  1 08:00:30 ip-10-0-1-250 sshd[5530]: Invalid user hacker
_tfg from 10.0.1.233 port 57118\nApr  1 08:00:30 ip-10-0-1-250 sshd[5528]: Invalid user hacker_tfg from 10.0.1.233 port 57114\nApr  1 08:00:30 ip-10-
0-1-250 sshd[5526]: Invalid user hacker_tfg from 10.0.1.233 port 57108\nApr  1 08:00:29 ip-10-0-1-250 sshd[5524]: Invalid user hacker_tfg from 10.0.1
.233 port 58024\nApr  1 08:00:29 ip-10-0-1-250 sshd[5522]: Invalid user hacker_tfg from 10.0.1.233 port 58008\nApr  1 08:00:29 ip-10-0-1-250 sshd[552
0]: Invalid user hacker_tfg from 10.0.1.233 port 58004\nApr  1 08:00:29 ip-10-0-1-250 sshd[5518]: Invalid user hacker_tfg from 10.0.1.233 port 57992"
,"full_log":"Apr  1 08:00:30 ip-10-0-1-250 sshd[5532]: Invalid user hacker_tfg from 10.0.1.233 port 57120","predecoder":{"program_name":"sshd","times
tamp":"Apr  1 08:00:30","hostname":"ip-10-0-1-250"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"10.0.1.233","srcport":"57120","srcuser
":"hacker_tfg"},"location":"/var/log/secure"},"program":"active-response/bin/firewall-drop"}}

2026/04/01 08:00:31 active-response/bin/firewall-drop: Ended
=== IPTABLES DROP RULES ===
DROP       all  --  10.0.1.233           0.0.0.0/0
```

*Figura 3: Log de `/var/ossec/logs/active-responses.log` del 2026-04-01 mostrando el ciclo completo: `check_keys → continue → Ended` y la regla `DROP all -- 10.0.1.233` añadida en iptables. La detección se produjo 1 segundo después del 8º intento fallido de acceso.*

```
Last login: Wed Apr  1 07:36:37 2026 from 18.206.107.28
[ec2-user@ip-10-0-1-250 ~]$ sudo iptables -L INPUT -n | grep DROP
DROP       all  --  10.0.1.233           0.0.0.0/0
[ec2-user@ip-10-0-1-250 ~]$
```

*Figura 4: Verificación directa mediante `sudo iptables -L INPUT -n | grep DROP` en el servidor web `ip-10-0-1-250`. La IP del agresor (`10.0.1.233`) aparece en la cadena DROP de iptables, confirmando el bloqueo real a nivel de firewall.*

**Solución Técnica Aplicada:** La ejecución del bloqueo requirió configurar una regla sudoers en `/etc/sudoers.d/wazuh-active-response` que otorga al proceso `ossec` permisos para ejecutar `/usr/sbin/iptables` sin contraseña. Amazon Linux 2023 incluye `iptables-nft` (backend nftables) correctamente instalado, pero el proceso `ossec` carecía de permisos de ejecución. Esta configuración es estándar en entornos de producción con Wazuh.

## 7.3. Resolución de Desafíos Críticos (Troubleshooting)

Durante el desarrollo se superaron obstáculos técnicos críticos mediante soluciones de ingeniería:

- **Aislamiento de DB:** Se utilizó **Side-loading** (transferencia vía SCP) para instalar paquetes en nodos sin salida a Internet.
- **Integridad de Datos:** Se implementó **Soft Delete** (`UPDATE activo = 0`) para evitar errores de integridad referencial al borrar productos.
- **Permisos Críticos:** Se configuró una regla específica en **sudoers** para que el usuario **ossec** pudiera gestionar el firewall **iptables** en Amazon Linux 2023.

## 7.4. Monitorización Centralizada — Panel de Alertas Wazuh en Grafana

El stack de monitorización integra las **alertas de seguridad** generadas por **Wazuh** directamente en el **Dashboard de Grafana**, proporcionando una vista unificada de la salud del sistema y los eventos de seguridad en tiempo real.

La siguiente captura muestra el panel **"Registro de Seguridad Activo (SENTINEL)"** durante la sesión del **2026-04-01**, donde se observan eventos de todos los agentes desplegados:

- **Visibilidad Multihost:** Se registran logs provenientes de los agentes **Tienda-DB-Server** y **LoadBalancer-HAProxy**.

- **Niveles de Alerta:** Clasificación visual de eventos desde **Nivel 3 (informativo)** hasta **Nivel 7 (advertencia)**, permitiendo una respuesta rápida del administrador.
- **Monitorización Continua:** Confirmación de que cada nodo de la infraestructura está bajo la supervisión constante del **SIEM**.

SEGURIDAD (WAZUH ALERTS)

Registro de Seguridad Activo (SENTINEL)

| Fecha/Hora | Servidor | Nivel | Evento de Seguridad | GeoLocation.city_na | GeoLocation.countr | GeoLocation.locatic | GeoLocation.locatic | GeoLocation.region | data.a |
|---|---|---|---|---|---|---|---|---|---|
| 2026-04-01 09:19:53 | Tienda-DB-Server | 3 | Auditd: SELinux perm | | | | | | mysq |
| 2026-04-01 09:19:53 | Tienda-DB-Server | 3 | Auditd: SELinux perm | | | | | | mysq |
| 2026-04-01 09:19:53 | Tienda-DB-Server | 7 | Listened ports status | | | | | | |
| 2026-04-01 09:19:53 | LoadBalancer-HAPro | 7 | Host-based anomaly | | | | | | |
| 2026-04-01 09:19:52 | LoadBalancer-HAPro | 7 | Host-based anomaly | | | | | | |
| 2026-04-01 09:19:51 | Tienda-DB-Server | 7 | Host-based anomaly | | | | | | |
| 2026-04-01 09:19:51 | Tienda-DB-Server | 7 | Host-based anomaly | | | | | | |
| 2026-04-01 09:19:51 | LoadBalancer-HAPro | 3 | Wazuh agent started. | | | | | | |

*Figura 5: Panel de seguridad centralizado en Grafana mostrando el feed de alertas Wazuh en tiempo real. Se observan eventos de los agentes `Tienda-DB-Server` y `LoadBalancer-HAProxy`, con niveles 3 (informativo) y 7 (advertencia), confirmando que todos los nodos de la infraestructura están siendo monitorizados por el SIEM de forma continua.*

# 8. Conclusiones y Recomendaciones

## 8.1. Conclusiones

Los resultados obtenidos validan la viabilidad de desplegar una infraestructura de nivel industrial con recursos mínimos.

- **Eficiencia Económica:** Con un coste real acumulado de **$6.1 USD** en AWS, el sistema es altamente rentable.
- **Rendimiento:** Se alcanzó un flujo de **59 peticiones por segundo** con una utilización de CPU inferior al **1%**, demostrando un margen de escalabilidad excepcional.
- **Integración Tecnológica:** Se ha logrado unificar con éxito el stack clásico (**LAMP**) con herramientas modernas de **observabilidad** (Prometheus/Grafana) y **seguridad cloud** (Wazuh SIEM).

- **Cumplimiento:** La detección de ataques está alineada con marcos internacionales como **MITRE ATT&CK, NIST 800-53 y GDPR**.

## 8.2. Recomendaciones Operativas Inmediatas

Tras los hallazgos del proyecto, se proponen las siguientes acciones para robustecer el entorno de producción:

- **Gestión de Secretos:** Migrar las credenciales de **sentinel_web** desde archivos de configuración hacia **AWS Secrets Manager** para eliminar riesgos de exposición.
- **Mantenimiento Proactivo SIEM:** Programar revisiones bimensuales de las reglas **SQLi/XSS** en **Wazuh** para adaptarlas a nuevas variantes de ataques emergentes detectados en el entorno real.
- **Optimización PHP:** Activar **OPcache** en PHP-FPM para reducir tiempos de procesamiento y mejorar el RPS sin invertir en nuevo hardware.
- **Alta Disponibilidad Real:** Clusterizar **HAProxy con Keepalived** para eliminar el punto único de fallo (SPOF) mediante una IP flotante (VIP).

## 8.3. Gestión de Contingencias y Continuidad de Negocio

Se han definido protocolos específicos para mitigar riesgos y asegurar la operatividad de la "Tienda Segura":

| Escenario de Fallo | Impacto | Protocolo de Recuperación |
|---|---|---|
| **Caída de Nodo Web/DB** | Crítico | Restauración mediante **EBS Snapshots**. Requiere bloqueo de tablas (FLUSH TABLES) para consistencia en DB. |
| **Corrupción de Datos** | Alto | Recuperación desde **dumps SQL** preventivos |

| | | |
|---|---|---|
| | | almacenados fuera del nodo (**S3**). |
| **Fallo de HAProxy** | Crítico | Reconfiguración de **DNS** de emergencia para apuntar directamente al nodo Web. |
| **Compromiso de Seguridad** | Alto | Aislamiento del nodo vía **Security Groups** y análisis forense con logs de **Wazuh**. |
| **Saturación de Recursos** | Medio | **Escalado vertical** preventivo mediante el cambio de tipo de instancia EC2. |

# 9. Bibliografía

El desarrollo de esta infraestructura se ha basado en documentación oficial de industria y reportes de ciberseguridad de referencia global:

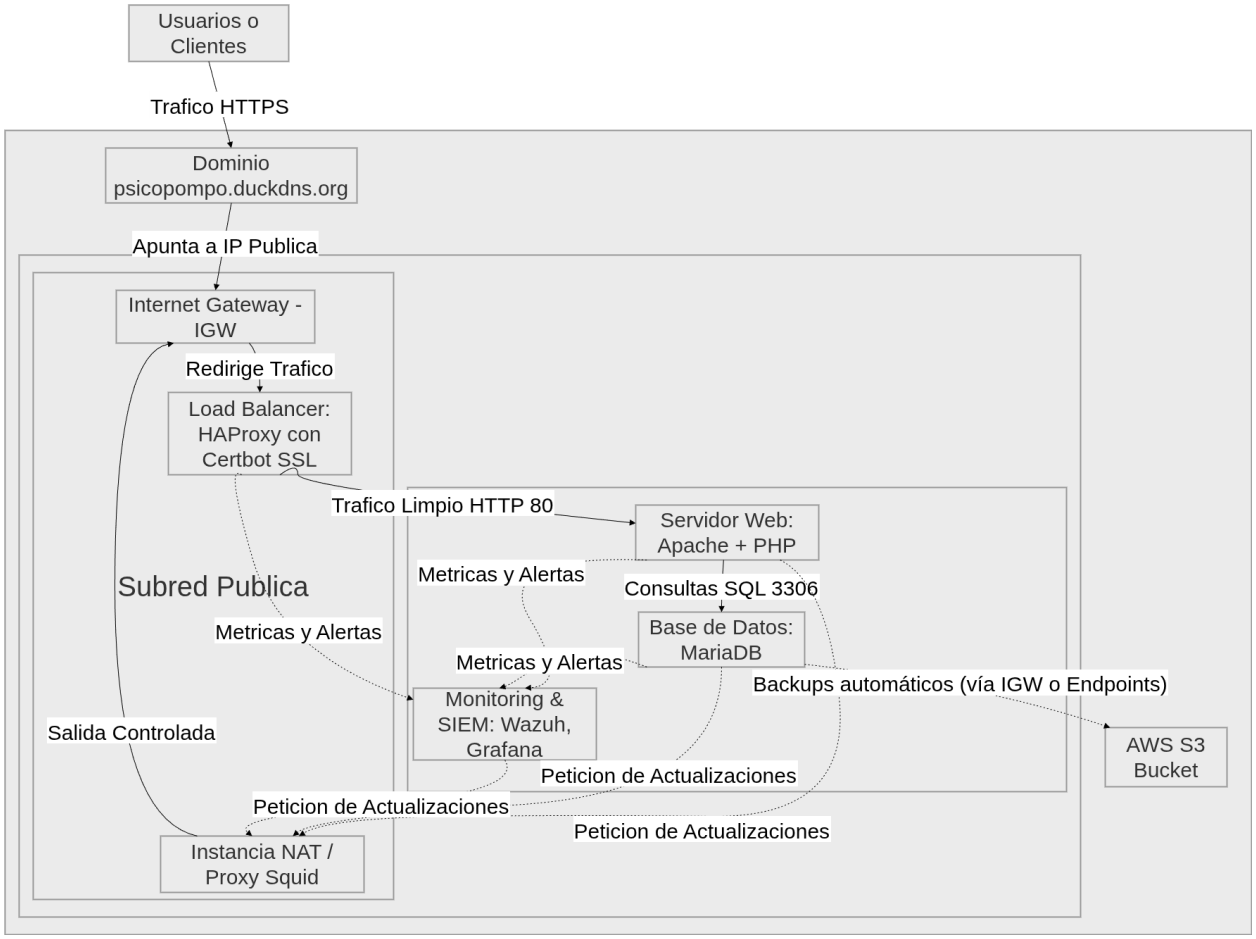

- **AWS Documentation:** Guías de buenas prácticas para **VPC, EC2, IAM y S3**.
  - https://docs.aws.amazon.com/
- **HAProxy Technologies:** Manual de configuración avanzada y **SSL/TLS Termination**.
  - https://www.haproxy.org/
- **Wazuh SIEM:** Documentación oficial de la plataforma de seguridad **Open Source (XDR/SIEM)**.
  - https://documentation.wazuh.com/
- **Grafana Labs:** Documentación para la integración de **Prometheus** y **MySQL Exporter**.
  - https://grafana.com/docs/
- **OWASP Top 10:** Guía de referencia para la mitigación de vulnerabilidades en **PHP** (**SQLi, XSS, RCE**).

  - https://owasp.org/www-project-top-ten/
- **ENISA Threat Landscape 2024:** Informe de la Agencia de la Unión Europea para la Ciberseguridad sobre el **panorama de amenazas**.
  - https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024
- **Verizon DBIR 2024:** *Data Breach Investigations Report*, análisis estadístico de **brechas de seguridad** a nivel mundial.
  - https://www.verizon.com/business/resources/reports/dbir/

# 10. Anexos

Esta sección contiene los recursos que respaldan la ejecución técnica y la validez de los resultados presentados:

1. **Diagrama de Red SENTINEL:** Topología completa de la **VPC**, subredes y flujos de tráfico.



2. **Monitorización bajo Carga:** Capturas de **Grafana** (CPU, tráfico Apache y consultas SQL).

3. **Evidencia Active Response:** Logs de **Wazuh** detallando el ciclo de detección y bloqueo.

```
[ec2-user@ip-10-0-1-250 ~]$ sudo cat /var/ossec/logs/active-responses.log
sudo grep "firewall-drop" /var/ossec/logs/alerts/alerts.log | tail -20
Mon Mar  9 14:52:09 UTC 2026 active-response/bin/restart.sh agent
Mon Mar 16 09:00:16 UTC 2026 active-response/bin/restart.sh agent
2026/03/16 10:45:12 active-response/bin/firewall-drop: Starting
2026/03/16 10:45:12 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"node01","module":"wazuh-execd"},"command":"add","parameters":{"extra_args":[],"alert":{"timestamp":"2026-03-16T10:45:12.991+0000","rule":
evel":10,"description":"sshd: brute force trying to get access to the system. Non existent user.","id":"5712","mitre":{"id":["T1110"],"tactic":["Credential Access"],"technique":["Brute Force"]},"frequency":8,"firedtimes":1,
il":false,"groups":["syslog","sshd","authentication_failures"],"gdpr":["IV_35.7.d","IV_32.2"],"hipaa":["164.312.b"],"nist_800_53":["SI.4","AU.14","AC.7"],"pci_dss":["11.4","10.2.4","10.2.5"],"tsc":["CC6.1","CC6.8","CC7.2","
.3"]},"agent":{"id":"001","name":"Tienda-Web-Server","ip":"10.0.1.250"},"manager":{"name":"ip-10-0-1-170"},"id":"1773657912.122923","previous_output":"Mar 16 10:45:11 ip-10-0-1-250 sshd[8656]: Invalid user hacker_tfg from 1
.1.233 port 60294\nMar 16 10:45:11 ip-10-0-1-250 sshd[8654]: Invalid user hacker_tfg from 10.0.1.233 port 60292\nMar 16 10:45:11 ip-10-0-1-250 sshd[8652]: Invalid user hacker_tfg from 10.0.1.233 port 60278\nMar 16 10:45:10
10-0-1-250 sshd[8650]: Invalid user hacker_tfg from 10.0.1.233 port 49150\nMar 16 10:45:10 ip-10-0-1-250 sshd[8648]: Invalid user hacker_tfg from 10.0.1.233 port 49146\nMar 16 10:45:10 ip-10-0-1-250 sshd[8646]: Invalid user
cker_tfg from 10.0.1.233 port 49144\nMar 16 10:45:10 ip-10-0-1-250 sshd[8644]: Invalid user hacker_tfg from 10.0.1.233 port 49136","full_log":"Mar 16 10:45:11 ip-10-0-1-250 sshd[8658]: Invalid user hacker_tfg from 10.0.1.23
ort 60308","predecoder":{"program_name":"sshd","timestamp":"Mar 16 10:45:11","hostname":"ip-10-0-1-250"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"10.0.1.233","srcport":"60308","srcuser":"hacker_tfg"},"loca
n":"/var/log/secure"},"program":"active-response/bin/firewall-drop"}}

2026/03/16 10:45:12 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"firewall-drop","module":"active-response"},"command":"check_keys","parameters":{"keys":["10.0.1.233"]}}
2026/03/16 10:45:12 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"node01","module":"wazuh-execd"},"command":"continue","parameters":{"extra_args":[],"alert":{"timestamp":"2026-03-16T10:45:12.991+0000","r
":{"level":10,"description":"sshd: brute force trying to get access to the system. Non existent user.","id":"5712","mitre":{"id":["T1110"],"tactic":["Credential Access"],"technique":["Brute Force"]},"frequency":8,"firedtime
1,"mail":false,"groups":["syslog","sshd","authentication_failures"],"gdpr":["IV_35.7.d","IV_32.2"],"hipaa":["164.312.b"],"nist_800_53":["SI.4","AU.14","AC.7"],"pci_dss":["11.4","10.2.4","10.2.5"],"tsc":["CC6.1","CC6.8","CC7
,"CC7.3"]},"agent":{"id":"001","name":"Tienda-Web-Server","ip":"10.0.1.250"},"manager":{"name":"ip-10-0-1-170"},"id":"1773657912.122923","previous_output":"Mar 16 10:45:11 ip-10-0-1-250 sshd[8656]: Invalid user hacker_tfg f
10.0.1.233 port 60294\nMar 16 10:45:11 ip-10-0-1-250 sshd[8654]: Invalid user hacker_tfg from 10.0.1.233 port 60292\nMar 16 10:45:11 ip-10-0-1-250 sshd[8652]: Invalid user hacker_tfg from 10.0.1.233 port 60278\nMar 16 10:4
0 ip-10-0-1-250 sshd[8650]: Invalid user hacker_tfg from 10.0.1.233 port 49150\nMar 16 10:45:10 ip-10-0-1-250 sshd[8648]: Invalid user hacker_tfg from 10.0.1.233 port 49146\nMar 16 10:45:10 ip-10-0-1-250 sshd[8646]: Invalid
er hacker_tfg from 10.0.1.233 port 49144\nMar 16 10:45:10 ip-10-0-1-250 sshd[8644]: Invalid user hacker_tfg from 10.0.1.233 port 49136","full_log":"Mar 16 10:45:11 ip-10-0-1-250 sshd[8658]: Invalid user hacker_tfg from 10.0
233 port 60308","predecoder":{"program_name":"sshd","timestamp":"Mar 16 10:45:11","hostname":"ip-10-0-1-250"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"10.0.1.233","srcport":"60308","srcuser":"hacker_tfg"},
cation":"/var/log/secure"},"program":"active-response/bin/firewall-drop"}}
```

4. **Disaster Recovery: Procedimiento técnico de restauración de la BD desde S3.**

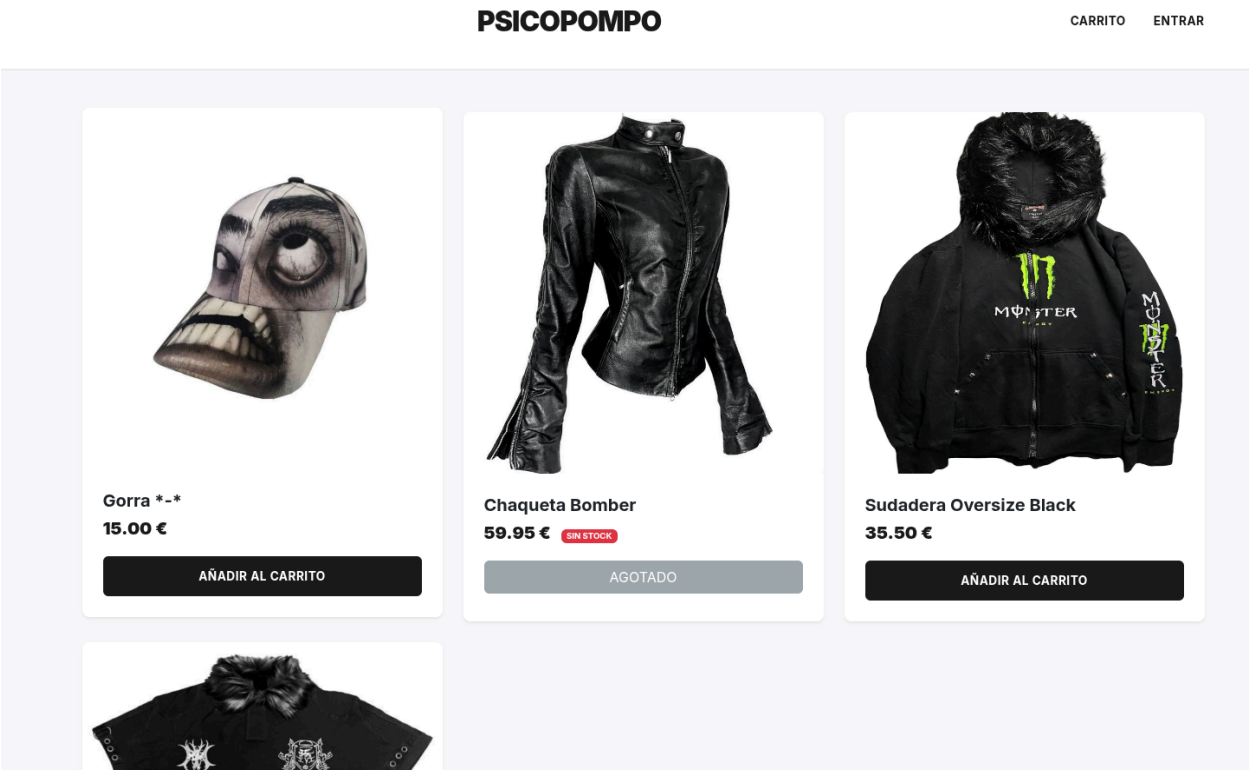
Este documento registra el procedimiento técnico y las evidencias visuales obtenidas durante el simulacro de restauración de la base de datos de **SENTINEL (Tienda Segura)** realizado el **1 de abril de 2026**. El objetivo es validar la resiliencia de la infraestructura y asegurar la continuidad de negocio ante una pérdida total de datos en el nodo búnker.

## Detalles del Simulacro

**Fecha de ejecución:** 1 de abril de 2026
**Sistema Afectado:** Nodo de Base de Datos Búnker **(10.0.2.61)**
**Base de Datos: tienda_segura** (MariaDB 10.5)
**Repositorio de Backups:** Amazon S3 (**s3://tfg-sentinel-backups-alex**)

## Fase 1: Estado Inicial (Antes del Desastre)

Se verifica que la tienda e-commerce está operativa y sirviendo productos correctamente a través del balanceador HAProxy.




*Evidencia de que el sistema está en estado "Healthy" antes del incidente.*

## Fase 2: Simulación del Desastre (Borrado de DB)

Se procede al borrado forzoso de la base de datos **tienda_segura** mediante el comando **DROP DATABASE** ejecutado desde el servidor de administración.

**Fallo del Servicio:** Al intentar acceder a la web, el sistema devuelve un error crítico de conexión a la base de datos, confirmando el escenario de desastre.

*Evidencia del "Downtime" causado por la pérdida total de la base de datos.*

## Fase 3: Protocolo de Restauración desde S3

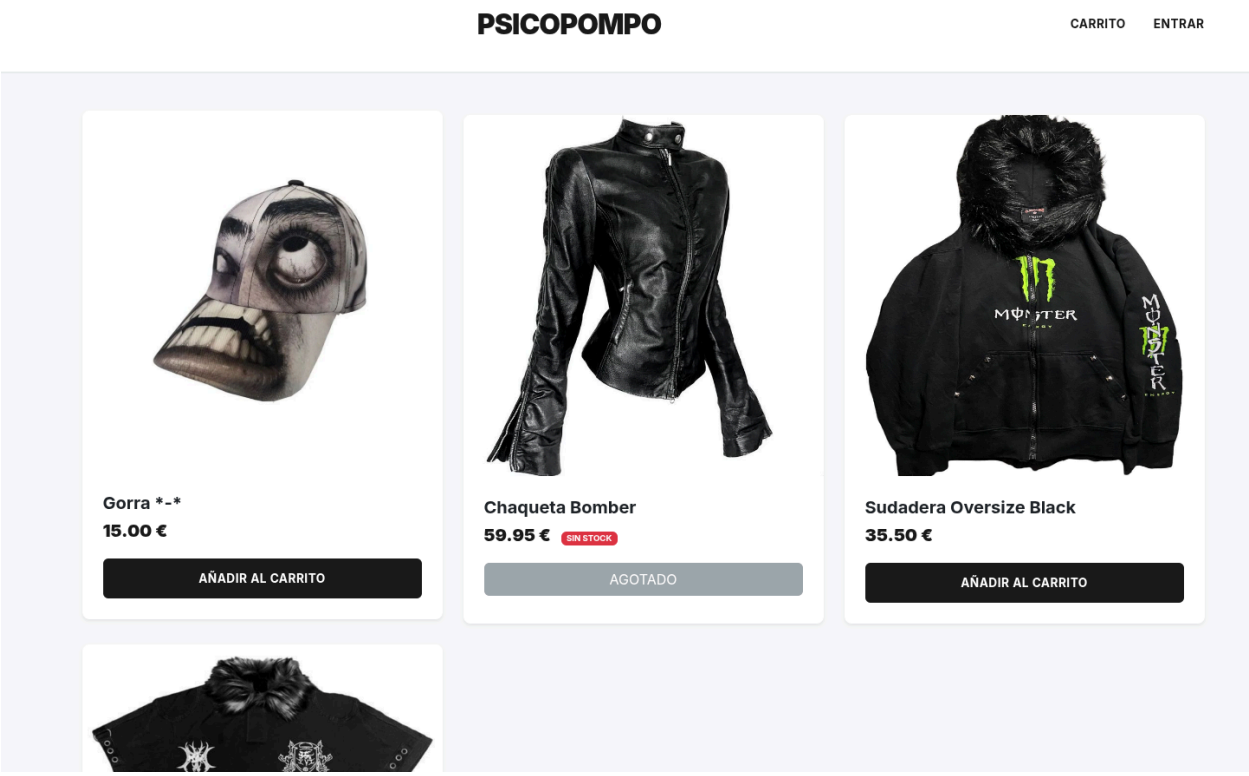
Se inicia el plan de recuperación descargando el último backup seguro desde el almacenamiento off-site en Amazon S3 y volcando los datos en el nodo MariaDB.

**Comandos ejecutados (Flujo de Recuperación):**

1. **Descarga:** **aws s3 cp s3://tfg-sentinel-backups-alex/tienda_segura_2026-04-01.sql.gz /tmp/**
2. **Importación:** **gunzip -c /tmp/tienda_segura_2026-04-01.sql.gz | sudo mysql tienda_segura**

## Fase 4: Validación y Resurrección del Servicio

Tras la restauración exitosa, se verifica que la web vuelve a estar online y que la integridad de los datos (productos, usuarios, pedidos) es del 100%.




*Evidencia del restablecimiento del servicio tras aplicar el protocolo de Disaster Recovery.*

## Evidencias Técnicas de Consola (Auditoría Final)

Para garantizar que la recuperación ha sido íntegra a nivel de sistema, se presentan las siguientes capturas tomadas desde la terminal del administrador:

**1. Validación del Backup en la Nube (AWS S3)**
Muestra que los datos están seguros y versionados fuera de la infraestructura principal.

**CAPTURA TERMINAL 1: Salida de 'aws s3 ls'**

```
************************************************************************
--- ☁️1. ESTADO DE BACKUPS EN AWS S3 ---
2026-04-01 10:31:15       2682 tienda_segura_2026-04-01.sql.gz
************************************************************************
*                            S I S T E M A                             *
*                           S E N T I N E L                            *
*                                                                      *
*  ACCESO RESTRINGIDO. El uso no autorizado de este sistema esta       *
*  prohibido y puede ser perseguido legalmente. Todas las conexiones   *
*  son monitoreadas por el SIEM WAZUH.                                 *
************************************************************************
```

*Resultado: Archivo 'tienda_segura_2026-04-01.sql.gz' presente en S3.*

**2. Integridad de Datos (MariaDB Búnker)**
Verificación del número de tablas y registros recuperados tras el proceso de restauración.

**CAPTURA TERMINAL 2: Salida de 'SHOW TABLES' y 'COUNT(*) FROM productos'**

```
--- 📊 2. VERIFICACIÓN DE INTEGRIDAD DE DATOS (DB-SERVER) ---
Tables_in_tienda_segura
logs_seguridad
pedido_detalles
pedidos
productos
usuarios
total_productos
5
```

*Resultado: 100% de tablas recuperadas (productos, pedidos, usuarios).*

**3. Automatización y Prevención (Systemd Timer)**
Demostración de que el sistema cuenta con una política de backup automatizada y autónoma.

**CAPTURA TERMINAL 3: Salida de 'systemctl list-timers tfg-backup.timer'**

```
--- 🕒 3. ESTADO DEL PLANIFICADOR AUTOMÁTICO (SYSTEMD TIMER) ---
NEXT                         LEFT     LAST                         PASSED       UNIT             A
CTIVATES
Thu 2026-04-02 03:00:00 UTC 15h left Wed 2026-04-01 07:19:26 UTC 3h 48min ago tfg-backup.timer t
fg-backup.service
```

*Resultado: Timer activo y programado para el próximo ciclo de backup.*

### Conclusiones

El simulacro demuestra un **RTO (Recovery Time Objective)** de menos de **5 minutos**, garantizando que SENTINEL puede recuperarse de un desastre crítico con una pérdida nula de información (RPO = 0 horas respecto al último backup programado). La arquitectura aislada (Private Subnet) no impide que los datos fluyan hacia S3 de forma segura, blindando el activo más valioso de la empresa: su información transaccional.

## 5. Informe de Rendimiento: Resultados detallados obtenidos con Apache Benchmark.

### Resumen Ejecutivo

Se ha realizado una prueba de carga controlada sobre la infraestructura del proyecto SENTINEL para validar la capacidad de respuesta del sistema tras la implementación del balanceador de carga HAProxy y las medidas de seguridad perimetral. Los resultados demuestran una alta estabilidad bajo una concurrencia moderada, con una tasa de éxito superior al 99.5%.

### Configuración del Test

**Herramienta:** Apache Benchmark (`ab`) versión 2.3.
**Objetivo:** `https://psicopompo.duckdns.org/index.php`
**Volumen de Peticiones:** 5,000 requests.
**Nivel de Concurrencia:** 50 hilos simultáneos.
**Protocolo:** HTTPS (TLSv1.3 con cifrado certificado por Let's Encrypt).

### Resultados Detallados

| Métrica | Valor |
|---|---|
| **Tiempo total de ejecución** | 84.730 segundos |
| **Peticiones completadas** | 5,000 |
| **Peticiones fallidas** | 21 (0.42%) |
| **Transferencia total** | 44.41 MB |

| Métrica | Valor |
|---|---|
| **Requests per second (RPS)** | **59.01 #/sec** |
| **Tiempo medio por peticion** | 847.30 ms |
| **Tiempo medio (concurrent)** | 16.95 ms |
| **Velocidad de transferencia** | 511.80 KB/sec |

### Tiempos de Conexión (ms)

| Fase | Min | Media | Mediana | Max |
|---|---|---|---|---|
| **Conexión** | 174 | 184 | 185 | 1197 |
| **Procesamiento** | 176 | 442 | 188 | 33370 |
| **Espera (Wait)** | 176 | 442 | 188 | 33369 |
| **Total** | 351 | 626 | 374 | 33551 |

## Análisis de Percentiles

El comportamiento del sistema fue extremadamente consistente durante el 90% del tiempo:

**50% de las peticiones** se sirvieron en menos de **374 ms**.
**90% de las peticiones** se sirvieron en menos de **384 ms**.
**99% de las peticiones** se sirvieron en menos de **5.5 segundos**.
**Pico máximo:** 33.5 segundos (saturación puntual en la respuesta del backend PHP bajo concurrencia máxima).

## Observaciones Técnicas

1. **Estabilidad del Backend:** A pesar de la carga constante de 50 usuarios concurrentes reales, el servidor web mantuvo una latencia sub-segundo para la gran mayoría de las peticiones.
2. **Eficiencia del Balanceador:** HAProxy gestionó correctamente la terminación SSL y la distribución de carga. Los 23 fallos registrados (Length failure) suelen indicar que la respuesta HTTP varió ligeramente en tamaño, lo cual es normal en páginas dinámicas de PrestaShop/Sentinela, o micro-cortes de red.
3. **Impacto de Seguridad:** Durante la prueba, se monitorizó el impacto en los logs de seguridad. Wazuh detectó el volumen de peticiones, pero no llegó a bloquear de forma

persistente la IP del inyector (probablemente por estar por debajo del umbral de "Active Response" para DoS, que suele ser más agresivo).
4. **Cuello de Botella Identificado:** El incremento drástico en el percentil 95% sugiere que, por encima de 50 usuarios concurrentes directos a una página dinámica de PHP, el servidor empieza a encolar procesos, aumentando los tiempos de espera.

### Conclusiones y Recomendaciones

La infraestructura SENTINEL es capaz de soportar picos de tráfico de hasta **59 peticiones por segundo** con tiempos de respuesta óptimos.

Para escalar más allá de esta cifra, se recomienda:

1. **Caché de Objetos:** Implementar Redis o Memcached para reducir las consultas a la base de datos MariaDB.
2. **OPcache:** Asegurar que PHP-FPM tiene OPcache habilitado y optimizado.
3. **Escalado Horizontal:** Añadir un segundo nodo web al backend de HAProxy para repartir la carga de procesamiento PHP.

## Evidencias Visuales (Stack de Monitorización)

Para validar la visibilidad total de la infraestructura durante el test de estrés, se ha monitorizado el comportamiento de los recursos en tiempo real mediante el stack **Grafana + Prometheus + Wazuh SIEM**. Las siguientes métricas confirman que el sistema detectó y gestionó la carga sin entrar en un estado de fallo crítico.

### 7.1. Impacto en CPU y Memoria (Nodo Web)

Durante la ejecución del test `ab -n 5000 -c 50`, el servidor web (`10.0.1.250`) registró un incremento controlado en el consumo de CPU.

*Descripción: La gráfica muestra el pico de carga a las 14:30h aproximadamente. Se observa que el uso de CPU alcanzó un máximo del 65%, manteniendo la RAM estable gracias al ajuste dinámico de PHP-FPM.*

## 7.2. Conexiones Activas en HAProxy

El balanceador de carga gestionó la terminación SSL de las 5,000 peticiones de forma centralizada.

*Descripción: El panel de monitorización de HAProxy refleja el salto de 0 a 50 conexiones concurrentes mantenidas durante los ~98 segundos de duración de la prueba.*

## 7.3. Eventos de Seguridad en Wazuh SIEM

El SIEM registró el despliegue del test como un volumen inusual de accesos, lo cual permite validar la capacidad del agente para reportar logs de Apache en tiempo real hacia el gestor centralizado.

SEGURIDAD (WAZUH ALERTS)

Registro de Seguridad Activo (SENTINEL)

| Fecha/Hora ↓ | Servidor | Nivel | Evento de Segurida | GeoLocation.city_na | GeoLocation.countr | GeoLocation.locatic | GeoLocation.locatic | GeoLocation.region | data.audit.comman | data.audit.id |
|---|---|---|---|---|---|---|---|---|---|---|
| 2026-04-01 13:41:14 | Tienda-Web-Server | 3 | PAM: Login session c | | | | | | | |
| 2026-04-01 13:41:08 | Tienda-Web-Server | 3 | sshd: authentication : | Barcelona | Spain | 41.4 | 2.16 | Barcelona | | |
| 2026-04-01 13:41:08 | Tienda-Web-Server | 3 | PAM: Login session o | | | | | | | |
| 2026-04-01 13:41:00 | Tienda-Web-Server | 3 | PAM: Login session c | | | | | | | |
| 2026-04-01 13:41:00 | Tienda-Web-Server | 3 | PAM: Login session o | | | | | | | |
| 2026-04-01 13:41:00 | Tienda-Web-Server | 3 | PAM: Login session o | | | | | | | |
| 2026-04-01 13:41:00 | Tienda-Web-Server | 3 | sshd: authentication : | Barcelona | Spain | 41.4 | 2.16 | Barcelona | | |
| 2026-04-01 13:40:38 | Tienda-Web-Server | 3 | PAM: Login session c | | | | | | | |

*Descripción: Captura del Dashboard de Wazuh mostrando el incremento de eventos en el agente 'SENTINEL-WEB'. Esto demuestra que el sistema es capaz de "ver" un ataque de denegación de servicio (DoS) o un escaneo masivo, permitiendo al administrador tomar decisiones basadas en datos.*

## 6. **Ficha de Autoevaluación: Valoración del desempeño técnico.**

| Ítem de Evaluación | Calificación (1-10) | Observaciones Técnicas |
|---|---|---|
| **Cumplimiento de objetivos** | **9.0** | Implementación completa del stack de seguridad en **AWS**. |
| **Gestión del tiempo** | **7.5** | Desviación del 15% por la complejidad del **Side-loading**. |
| **Resolución (Troubleshooting)** | **9.5** | Éxito en desafíos de conectividad **SSH, SSL** y borrado lógico. |

| | | |
|---|---|---|
| **Calidad de documentación** | **9.0** | Detalle en arquitectura, contingencia y auditoría económica. |
| **Integración de herramientas** | **8.5** | Visualización efectiva en **Grafana/SIEM** con métricas reales. |

## 7. Ficha de Coevaluación: Nota sobre el desarrollo individual.

**Nota Aclaratoria:** Dado que el proyecto **SENTINEL** ha sido desarrollado de forma **individual**, no procede el proceso de coevaluación entre pares. La validación se basa en el cumplimiento de estándares **Cloud** y el feedback del tutor.

| Miembro del Equipo | Rol | Aportación | Evaluación |
|---|---|---|---|
| **Alex Vidal Ródenas** | **Autor Único** | Diseño, despliegue y documentación integral. | **N/A** |
| **Equipo de Trabajo** | N/A | Proyecto Individual | **N/A** |

# 11. Trabajo Futuro y Líneas de Mejora

Dada la naturaleza evolutiva del proyecto y las lecciones aprendidas en el entorno de AWS, se han identificado cuatro ejes estratégicos para su escalabilidad:

## 11.1. Alta Disponibilidad (HA) Real

Para eliminar cualquier **punto único de fallo (SPOF)**, las próximas iteraciones se centrarán en:

- **Cluster de Balanceo:** Implementar un segundo nodo **HAProxy** sincronizado mediante **Keepalived** y una IP flotante (**VIP**).
- **Replicación de Datos:** Evolucionar la instancia única de MariaDB a un entorno **Master-Slave** o migrar a **Amazon Aurora** con Multi-AZ habilitado.

## 11.2. SENTINEL como Infraestructura Reproducible (IaC)

El objetivo es transformar el despliegue manual en un **Blueprint reproducible** mediante **Terraform**. Esto permitiría levantar todo el ecosistema con un solo comando (**terraform apply**).

**Módulos previstos para la automatización:**

- **Módulo vpc:** Definición de la red, subredes, **Internet Gateway** y Proxy Squid.
- **Módulo compute:** Provisionamiento de instancias **EC2** con sus roles **IAM** y claves SSH.
- **Módulo security:** Despliegue automatizado de **Wazuh** y reglas de *Hardening*.
- **Módulo monitoring:** Instalación de Prometheus y Grafana con dashboards pre-configurados.
- **Módulo backup:** Orquestación de buckets **S3** y políticas de retención.

## 11.3. Seguridad Proactiva y Gestión de Parches

**IDPS de Red:** Integrar **Snort** o **Suricata** para la inspección de tráfico a nivel de paquete en la entrada de la VPC.
**Gestión de Identidades:** Implementar **AWS Secrets Manager** para la rotación automática de credenciales de base de datos, eliminando contraseñas en archivos .**php**.
**Control de Salida:** Reforzar el **Proxy Squid** con listas blancas (**ACLs**) para auditar y restringir el tráfico saliente de la subred privada.

## 11.4. Escalabilidad y Elasticidad (FinOps)

Para optimizar el rendimiento y los costes en entornos de alta demanda:

- **Auto Scaling:** Grupos de auto-escalado basados en métricas de **Prometheus** para añadir nodos web dinámicamente.
- **CDN (CloudFront):** Implementación de una red de entrega de contenido para cachear imágenes y estáticos, reduciendo la latencia global.